

Grille de correction — Travail de session

Titre de l'évaluation

Architecture sécurisée d'une plateforme pédagogique conteneurisée sur VM as Code

Informations de correction

- **Pondération totale** : 40 points.
- **Valeur dans le cours** : 40 % de la note finale.
- **Format de réalisation** : équipe de 3 à 5 étudiants.
- **Livrables à corriger** : vidéo hébergée sur Microsoft 365, GitBook, dépôt GitHub, document Word ou PowerPoint.
- **Durée maximale de la vidéo** : 15 min 59 s.

Cette grille vise à uniformiser la correction d'un travail de session portant sur une plateforme pédagogique conteneurisée déployée sur une VM initialisée par cloud-init. L'évaluation porte sur la cohérence de l'architecture, la sécurité des conteneurs, la capacité de démonstration, la qualité de l'intégration visuelle sans codage avancé, et la qualité des livrables remis.[cite:10][cite:51]

Rappel du scénario attendu

Le scénario pédagogique attendu est le suivant : un utilisateur consulte une offre de formation dans **Drupal Commerce**, effectue un paiement fictif, simulé ou en environnement sandbox, puis un **workflow n8n** attribue ou synchronise un droit d'accès dans **Moodle**. L'utilisateur accède ensuite au contenu pédagogique dans Moodle, avec **Keycloak** comme mécanisme d'identité et de SSO, **Traefik** comme reverse proxy, **OpenAppSec** comme couche WAF, **Portainer CE** comme console graphique d'exploitation, et un volet de journalisation ou d'observabilité minimal si possible.[cite:62][cite:65][cite:73][cite:76][cite:89]

Livrables à vérifier

Le correcteur doit vérifier la présence et l'accessibilité des livrables suivants :

- vidéo sur Microsoft 365 ou Microsoft Stream;
- GitBook;
- dépôt GitHub;
- document Word ou PowerPoint de 10 pages maximum, page de garde incluse.

Si un livrable est absent, inaccessible ou manifestement incomplet, cela doit affecter le critère « Qualité des livrables » et, au besoin, d'autres critères associés.

Barème détaillé — 40 points

Critère	Points
1. VM as Code avec cloud-init	5
2. Architecture et schéma	5
3. Déploiement conteneurisé	4
4. Sécurité des images	4
5. Sécurité à l'exécution	5
6. Segmentation réseau	4
7. Intégration fonctionnelle Drupal Commerce → n8n → Moodle	4
8. IAM et SSO	4
9. Reverse proxy et WAF	2
10. Observabilité et exploitation	2
11. Qualité des livrables	5

Critère	Points
Total	40

1. VM as Code avec cloud-init — 5 points

Attentes

L'équipe doit démontrer l'usage réel d'un fichier **cloud-init** pour initialiser la machine virtuelle, au lieu d'une configuration entièrement manuelle. Le correcteur doit repérer des éléments comme la création d'utilisateur, la configuration de base, les mises à jour initiales, l'installation de Docker et la préparation de l'environnement de travail.

Répartition suggérée

- **5 points** : cloud-init complet, fonctionnel, bien structuré et réellement utile au déploiement.
- **4 points** : cloud-init pertinent mais partiellement incomplet ou peu expliqué.
- **2 à 3 points** : cloud-init très minimal ou essentiellement décoratif.
- **0 à 1 point** : absence de vrai cloud-init ou usage non démontré.

Indices de preuve

- fichier `user-data.yaml` ou équivalent présent;
- explication dans GitBook ou vidéo;
- étapes d'initialisation clairement automatisées.

2. Architecture et schéma — 5 points

Attentes

Le schéma d'architecture doit être lisible, cohérent avec ce qui est réellement déployé et montrer les principales zones de confiance, les flux réseau, les points d'exposition et le parcours métier. Le parcours attendu inclut **Drupal Commerce**, **n8n**, **Moodle**, **Keycloak**, **Traefik**, **OpenAppSec**, ainsi que les couches de données et d'exploitation lorsque présentes.

Répartition suggérée

- **5 points** : schéma clair, juste, complet et aligné avec le déploiement réel.
- **4 points** : schéma généralement bon, avec quelques oublis mineurs.
- **2 à 3 points** : schéma partiel, ambigu ou difficile à relier à la solution.
- **0 à 1 point** : schéma absent ou incorrect.

Vérifications utiles

- flux d'entrée via Traefik;
- présence du WAF;
- rôle de n8n dans l'intégration;
- séparation entre services exposés et services internes.

3. Déploiement conteneurisé — 4 points

Attentes

La solution doit être déployée avec **Docker Compose** et rester compréhensible pour un correcteur. Les services doivent être structurés, les dépendances cohérentes et les volumes ou paramètres essentiels correctement organisés.

Répartition suggérée

- 4 points : stack fonctionnelle, bien structurée, propre et reproductible.
- 3 points : stack presque complète avec quelques imprécisions mineures.
- 1 à 2 points : stack partiellement fonctionnelle ou difficile à reproduire.
- 0 point : solution non déployable ou incohérente.

4. Sécurité des images — 4 points

Attentes

Le correcteur doit vérifier si les images sont identifiées par des versions explicites, si les choix sont raisonnables et si un mécanisme de vérification ou de scan est présenté. OWASP recommande notamment l'usage d'images maintenues, l'analyse statique et l'attention portée à la provenance des composants.[cite:10][cite:13][cite:86]

Répartition suggérée

- 4 points : images bien choisies, versions explicites, scan ou justification convaincante.
- 3 points : bonnes pratiques visibles mais démonstration incomplète.
- 1 à 2 points : peu d'éléments de sécurité ou choix peu justifiés.
- 0 point : aucune preuve sérieuse de réflexion sur les images.

Exemples de preuves recevables

- versions figées dans Compose;
- scan présenté dans la vidéo ou le dépôt;
- justification d'une image officielle ou maintenue.

5. Sécurité à l'exécution — 5 points

Attentes

Le correcteur doit chercher des traces concrètes de moindre privilège : utilisateur non-root quand possible, absence de mode privilégié, limitations raisonnables, options de sécurité comme `no-new-privileges`, restrictions de montage et réflexion sur la surface d'attaque. OWASP recommande explicitement d'exécuter les conteneurs avec un utilisateur non privilégié et d'activer `no-new-privileges` lorsque compatible.[cite:10][cite:13][cite:14]

Répartition suggérée

- 5 points : bonnes pratiques visibles, expliquées et majoritairement appliquées.
- 4 points : plusieurs contrôles corrects, quelques écarts justifiés.
- 2 à 3 points : sécurité partielle ou surtout déclarative.
- 0 à 1 point : presque aucun durcissement réel.

Points d'observation

- absence de `privileged: true`;
- présence de restrictions utiles;
- démonstration ou explication dans le GitBook;
- secret non committé et gestion prudente des variables d'environnement.

6. Segmentation réseau — 4 points

Attentes

L'équipe doit démontrer une séparation entre les réseaux d'exposition, applicatifs et de données. OWASP souligne l'importance de la segmentation réseau, de la protection des interfaces sensibles et de la limitation d'exposition des microservices aux seuls consommateurs légitimes.[cite:13][cite:86]

Répartition suggérée

- **4 points** : segmentation claire, bien pensée, bien expliquée.
- **3 points** : segmentation présente mais perfectible.
- **1 à 2 points** : segmentation minimale ou peu cohérente.
- **0 point** : réseau plat ou services sensibles exposés inutilement.

Preuves attendues

- plusieurs réseaux Docker dédiés;
- services de données non exposés au public;
- justification des communications autorisées.

7. Intégration fonctionnelle Drupal Commerce → n8n → Moodle — 4 points

Attentes

Le correcteur doit valider que l'équipe a réellement compris le scénario métier. Drupal Commerce doit servir de couche de vente, n8n de couche d'orchestration visuelle, et Moodle de couche de consommation. Moodle expose des services web REST et des fonctions API permettant une intégration de ce type, ce qui rend le scénario pédagogique réaliste même sans programmation avancée.[cite:62][cite:65][cite:88][cite:91]

Répartition suggérée

- **4 points** : flux cohérent, démontré, compréhensible et bien documenté.
- **3 points** : flux présent mais partiellement simulé ou incomplet.
- **1 à 2 points** : logique annoncée mais peu démontrée.
- **0 point** : aucune intégration crédible entre les composants.

Le correcteur doit accepter

- paiement fictif;
- déclenchement manuel ou sandbox;
- preuve d'attribution d'accès sans développement complexe;
- démonstration par interface graphique n8n.

8. IAM et SSO — 4 points

Attentes

L'usage de Keycloak doit être démontré au minimum avec un SSO vers Moodle. Le correcteur doit vérifier que le rôle de l'identité est compris, que les flux d'authentification sont expliqués et que l'architecture ne repose pas sur des comptes locaux non maîtrisés.

Répartition suggérée

- **4 points** : SSO fonctionnel, bien démontré et bien expliqué.
- **3 points** : SSO partiellement fonctionnel ou démonstration incomplète.
- **1 à 2 points** : configuration présente mais peu convaincante.
- **0 point** : absence de mise en œuvre réelle.

9. Reverse proxy et WAF — 2 points

Attentes

Traefik doit être identifié comme point d'entrée et OpenAppSec comme couche de protection applicative. Le correcteur doit vérifier que l'équipe comprend le rôle de chacun et que l'exposition des services est centralisée.

Répartition suggérée

- **2 points** : proxy et WAF intégrés et correctement expliqués.
- **1 point** : présence partielle ou démonstration limitée.
- **0 point** : absence ou incompréhension manifeste.

10. Observabilité et exploitation — 2 points

Attentes

Portainer CE doit être utilisé comme console graphique pédagogique pour observer les conteneurs, leurs états et leurs journaux. La documentation Portainer permet d'accéder aux journaux d'un conteneur depuis l'interface, ce qui est pertinent pour des étudiants débutants.[cite:38][cite:87][cite:90][cite:93]

Une bonification qualitative peut être accordée dans ce critère si l'équipe ajoute un mécanisme léger de journalisation centralisée, par exemple Loki ou Grafana, sans pénaliser les équipes qui ont préféré stabiliser le cœur du projet.

Répartition suggérée

- **2 points** : Portainer CE opérationnel et utilisé intelligemment; diagnostic crédible montré.
- **1 point** : Portainer présent mais peu exploité dans la démonstration.
- **0 point** : aucun usage pédagogique réel de l'observabilité.

11. Qualité des livrables — 5 points

Attentes

Le correcteur doit juger la qualité globale des quatre livrables attendus. La vidéo doit être conforme à la durée, le GitBook structuré, le dépôt GitHub exploitable et le document de synthèse utile à la lecture rapide du projet.

Répartition suggérée

- **5 points** : tous les livrables sont complets, cohérents, clairs et professionnels.
- **4 points** : très bons livrables avec quelques défauts mineurs.
- **2 à 3 points** : livrables présents mais inégaux ou difficiles à exploiter.
- **0 à 1 point** : plusieurs livrables absents, non accessibles ou de faible qualité.

Vérifications rapides

- vidéo entre 15 min 00 s et 15 min 59 s;
- GitBook accessible et structuré;
- dépôt GitHub navigable;
- document Word ou PowerPoint ne dépassant pas 10 pages.

Pénalités majeures

Les éléments suivants doivent entraîner une pénalité importante, voire un échec dans certains critères :

- secrets réels dans le dépôt GitHub;
- conteneur applicatif en mode privilégié sans justification sérieuse;
- exposition directe de PostgreSQL, Redis, n8n ou d'interfaces d'administration sensibles sur Internet;

- absence réelle de cloud-init;
- incapacité à expliquer les réseaux, les flux ou les dépendances;
- vidéo dépassant 15 min 59 s;
- dépôt GitHub inutilisable ou incomplet.

Grille synthèse par équipe

Équipe	VM as Code /5	Architecture /5	Déploiement /4	Images /4	Exécution /5	Réseaux /4	Intégration /4	IAM/SSO /4	Proxy/WAF /2	Observabilité /2	Livrables /5

Commentaires du correcteur

Forces

-
-
-

Faiblesses

-
-
-

Recommandations

-
-
-